

2.6 Operator Session Confidentiality and Integrity

Control Type: Mandatory	Applies to architecture:	A1	A2	A3	A4	B
		•	•	•	•	•
Control Definition Control Objective: Protect the confidentiality and integrity of interactive operator sessions that connect to the on-premises or remote (operated by a service provider) Swift infrastructure or to a service provider Swift-related applications. In-scope components: - Interactive user, operator or management sessions performed from - dedicated and general-purpose operator PC - jump server - Any another intermediate system accessed or used from any of the above to connect to - jump server or any other intermediate system accessed or used from any of the above - systems hosting a Swift-related component (including interface, GUI, Swift and customer (client) connectors) - network devices protecting the secure zone or the customer client connectors - management console of a virtualisation or cloud platform hosting Swift-related components (including interface, GUI, Alliance Connect Virtual on Premises VPN, Swift and customer (client) connector) - interface applications, GUI and Swift or customer connector in the secure zone - customer client connector - Swift-related applications at the service provider - HSM - bridging servers (such as middleware or file transfer servers other than customer connectors) used for and guardian of the secure data exchange between back-office and Swift-related components] Risk Drivers: - loss of operational confidentiality - loss of operational integrity - password theft						
Implementation Guidance Control Statement: The confidentiality and integrity of interactive operator sessions that connect to service provider Swift-related applications or into the user's secure zone are safeguarded. Control Context: Operator sessions, through the jump server when accessing the on-premises or remote (that is hosted or operated by a third party, or both) Swift infrastructure, pose a unique threat because unusual or unexpected activity is more difficult to detect during interactive sessions than it is during application-to-application activity. Therefore, it is important to protect the integrity and confidentiality of these operator sessions to reduce any opportunity for misuse or password theft. When used, access to the virtualisation layer (virtualisation or cloud management console) must be similarly protected. Implementation Guidelines: The implementation guidelines are common methods to apply the relevant control. The guidelines are a helpful way to begin an assessment but should never be considered as an audit checklist as each user's implementation may vary. Therefore, in cases where some implementation guidelines elements are not present or partially covered, mitigations as well as particular environment specificities must be						

considered to properly assess the overall compliance adherence level (as per the suggested guidelines or as per the alternatives).

- All interactive sessions are protected by a cryptographic protocol (for example, ssh, https with one-way TLS). That includes the interactive flows to components or secure zones which span over multiple on-premises or remote (such as in the cloud) environments or a combination.
- Protocols use a current, commonly accepted cryptographic algorithm (for example, AES³¹ or ECDHE³²), with key lengths in line with the current best practices. More guidelines on cryptographic algorithms that support secure protocols can be found in the [Knowledge Base article 5021566](#).
- Operator sessions and other session types (for example, admin or maintenance) possess an inactivity lock-out feature that limits the session to the minimal time frame necessary to perform business-as-usual duties.
- If the inactivity lock-out is not implemented at the application level, then it should be implemented at the operating system level of the application, or on the jump server.
- The communication between the jump server (when used) and the Swift-related components or underlying systems, is protected using a secure mechanism (for example, one-way or two-way TLS) to support the confidentiality and integrity of the user's connection to the applications or the underlying systems.

Optional Enhancement:

- Apply the control to all bridging servers (such as middleware or file transfer servers other than customer connectors) used for data exchange between back-office and Swift-related components.

³¹ Advanced Encryption Standard

³² Elliptic Curve Diffie-Hellman Ephemeral